

DROWN: Breaking TLS Using SSLv2

DROWN: Breaking TLS Using SSLv2 - Author not stated, [usenix.org](https://www.usenix.org).

- Published: date not stated
- Original: <<https://www.usenix.org/conference/usenixsecurity16/technical-sessions/presentation/aviram>>
- Preserved from: <https://www.usenix.org/conference/usenixsecurity16/technical-sessions/presentation/aviram> (live) on 2026-08-08
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

DROWN: Breaking TLS Using SSLv2 | USENIX

[Back to USENIX](#)

DROWN: Breaking TLS Using SSLv2

Nimrod Aviram, *Tel Aviv University*; Sebastian Schinzel, *Münster University of Applied Sciences*; Juraj Somorovsky, *Ruhr University Bochum*; Nadia Heninger, *University of Pennsylvania*; Maik Dankel, *Münster University of Applied Sciences*; Jens Steube, *Hashcat Project*; Luke Valenta, *University of Pennsylvania*; David Adrian and J. Alex Halderman, *University of Michigan*; Viktor Dukhovni, *Two Sigma and OpenSSL*; Emilia Käsper, *Google and OpenSSL*; Shaanan Cohney, *University of Pennsylvania*; Susanne Engels and Christof Paar, *Ruhr University Bochum*; Yuval Shavitt, *Tel Aviv University*

We present DROWN, a novel cross-protocol attack on TLS that uses a server supporting SSLv2 as an oracle to decrypt modern TLS connections.

We introduce two versions of the attack. The more general form exploits multiple unnoticed protocol flaws in SSLv2 to develop a new and stronger variant of the Bleichenbacher RSA padding-oracle attack. To decrypt a 2048-bit RSA TLS ciphertext, an attacker must observe 1,000 TLS handshakes, initiate 40,000 SSLv2 connections, and perform 250 offline work. The victim client never initiates SSLv2 connections. We implemented the attack and can decrypt a TLS 1.2 handshake using 2048-bit RSA in under 8 hours, at a cost of \$440 on Amazon EC2. Using Internet-wide scans, we find that 33% of all HTTPS servers and 22% of those with browser-trusted certificates are vulnerable to this protocol-level attack due to widespread key and certificate reuse.

For an even cheaper attack, we apply our new techniques together with a newly discovered vulnerability in OpenSSL that was present in releases from 1998 to early 2015. Given an unpatched

SSLv2 server to use as an oracle, we can decrypt a TLS ciphertext in one minute on a single CPU—fast enough to enable man-in-the-middle attacks against modern browsers. We find that 26% of HTTPS servers are vulnerable to this attack.

We further observe that the QUIC protocol is vulnerable to a variant of our attack that allows an attacker to impersonate a server indefinitely after performing as few as 217 SSLv2 connections and 258 offline work.

We conclude that SSLv2 is not only weak, but actively harmful to the TLS ecosystem.

Nimrod Aviram, Tel Aviv University

Sebastian Schinzel, Münster University of Applied Sciences

Juraj Somorovsky, Ruhr University Bochum

Nadia Heninger, University of Pennsylvania

Maik Dankel, Münster University of Applied Sciences

Jens Steube, Hashcat Project

Luke Valenta, University of Pennsylvania

David Adrian, University of Michigan

J. Alex Halderman, University of Michigan

Viktor Dukhovni, Two Sigma and OpenSSL

Emilia Käsper, Google and OpenSSL

Shaanan Cohney, University of Pennsylvania

Susanne Engels, Ruhr University Bochum

Open Access Media

USENIX is committed to Open Access to the research presented at our events. Papers and proceedings are freely available to everyone once the event begins. Any video, audio, and/or slides that are posted after the event are also free and open to everyone. [Support USENIX](#) and our commitment to Open Access.

BibTeX

```
@inproceedings {197245, author = {Nimrod Aviram and Sebastian Schinzel and Juraj Somorovsky and Nadia Heninger and Maik Dankel and Jens Steube and Luke Valenta and David Adrian and J. Alex Halderman and Viktor Dukhovni and Emilia Kasper and Shaanan Cohney and Susanne Engels and Christof Paar and Yuval Shavitt}, title = {{DROWN}: Breaking {TLS} Using {SSLv2}}, booktitle = {25th USENIX Security Symposium (USENIX Security 16)}, year = {2016}, isbn = {978-1-931971-32-4}, address = {Austin, TX}, pages = {689--706}, url = {https://www.usenix.org/conference/usenixsecurity16/technical-sessions/presentation/aviram}, publisher = {USENIX Association}, month = aug }
```

[Download](#)

[Aviram PDF](#)

[View the slides](#)

Presentation Video

Presentation Audio

[MP3 Download](#)

[Download Audio](#)

Archived from <https://www.usenix.org/conference/usenixsecurity16/technical-sessions/presentation/aviram>. Rendered offline from the local Markdown copy.